

Manual 44 — Implementação controlada do NIST SSDF / SP 800-218

****Linha de base controlada:**** NIST SP 800-218 SSDF v1.1 final e SP 800-218A final como perfil comunitário de IA. SP 800-218 Rev.1 / SSDF v1.2 permanece em monitoramento até reavaliação como final na publicação.

Chapter 01 — Hierarquia de fontes e versões

Manter status final/rascunho, fontes autoritativas, datas, monitoramento de mudanças, responsáveis e evidências.

Chapter 02 — Escopo do SSDF

Definir produtos, serviços, código, infraestrutura, pipelines, fornecedores, componentes de IA e etapas do ciclo de vida.

Chapter 03 — Preparar a organização

Estabelecer políticas, funções, recursos, treinamento, ferramentas, ambientes, métodos de risco e governança.

Chapter 04 — Proteger o software

Proteger código-fonte, repositórios, builds, credenciais, artefatos, configurações e ambientes.

Chapter 05 — Produzir software bem protegido

Aplicar design, implementação, revisão, análise, testes, dependências, configuração e integridade de release.

Chapter 06 — Responder a vulnerabilidades

Operar recebimento, triagem, análise, remediação, divulgação, coordenação, verificação e lições aprendidas.

Chapter 07 — Governança e funções

Atribuir responsáveis em produto, engenharia, segurança, operações, compras, jurídico, privacidade, risco e direção.

Chapter 08 — Design seguro

Definir requisitos, limites de confiança, padrões seguros, proteção de dados e limites de privilégio.

Chapter 09 — Modelagem de ameaças

Identificar ativos, adversários, caminhos de ataque, casos de abuso, dependências, mitigação e risco residual.

Chapter 10 — Revisão de arquitetura

Revisar identidade, fluxos, isolamento, criptografia, resiliência, interfaces e premissas de implantação.

Chapter 11 — Controle de código-fonte

Proteger branches, commits, revisões, identidades, permissões, configurações, proveniência e histórico.

Chapter 12 — Integridade de build

Proteger serviços, runners, compiladores, dependências, configuração, isolamento, logs e artefatos.

Chapter 13 — Governança de dependências

Inventariar dependências diretas/transitivas e avaliar proveniência, vulnerabilidades, licenças e manutenção.

Chapter 14 — SBOM e proveniência

Gerar e proteger SBOM, metadados de origem, atestações, relações de componentes e retenção.

Chapter 15 — Segredos

Evitar segredos embutidos; controlar criação, armazenamento, entrega, varredura, rotação e revogação.

Chapter 16 — Codificação segura

Aplicar regras por linguagem/plataforma para entradas, saídas, erros, memória, autenticação e autorização.

Chapter 17 — Revisão de código e análise estática

Usar revisão por pares e análise automatizada, controlando achados, exceções e remediação.

Chapter 18 — Testes dinâmicos e de segurança

Usar testes unitários, integração, fuzzing, penetração, abuso, API e configuração conforme risco.

Chapter 19 — Controles CI/CD

Proteger definições, identidades, aprovações, ambientes, artefatos, segredos, logs e implantações.

Chapter 20 — Separação de ambientes

Separar desenvolvimento, teste, staging, produção, assinatura, dados sensíveis e atividades de alta confiança.

Chapter 21 — Integridade, assinatura e atestação de release

Verificar fonte aprovada, testes, dependências, proveniência, assinaturas, checksums e autorização.

Chapter 22 — Recebimento de vulnerabilidades

Manter canais internos/externos, divulgação coordenada, deduplicação, severidade e preservação de evidência.

Chapter 23 — Remediação e priorização

Priorizar por explorabilidade, exposição, impacto, alcance, controles compensatórios e exploração ativa.

Chapter 24 — Garantia de fornecedores

Avaliar desenvolvimento, serviços, componentes, dependências de build, incidentes e ações corretivas.

Chapter 25 — Aquisição de software

Definir requisitos de desenvolvimento seguro e avaliar evidências, vulnerabilidades, proveniência, manutenção e saída.

Chapter 26 — Feedback de incidentes

Incorporar incidentes, vulnerabilidades, red-team e postmortems em requisitos, design, treinamento e controles.

Chapter 27 — Controles do perfil de desenvolvimento de IA

Aplicar SP 800-218A quando relevante a modelos, código, dados, proveniência, avaliação e implantação.

Chapter 28 — Limites de sobreposições federais e contratuais

Manter SSDF separado de mandatos de agência, cláusulas, contratos, normas setoriais e requisitos internos.

Chapter 29 — Evidências e métricas

Medir adoção, cobertura, idade de vulnerabilidades, revisões, testes, dependências e exceções.

Chapter 30 — Exceções e melhoria contínua

Documentar exceções, aceitação de risco, controles compensatórios, expiração e ações corretivas.

Chapter 31 — Localização e proveniência

Congelar candidatos EN/es-419/pt-BR e vincular identidades DOCX/PDF a SHA-256 com evidências de QA.

Chapter 32 — Monitoramento de rascunhos e reverificação final

Antes de publicar, confirmar status NIST, publicação do Manual 43, identidade exata e QA limpo.